

Network Security and Modern Technologies

Securing Modern Networks, Cloud Infrastructure, and Zero Trust Architectures

FDSI



What is Network Security?

The practice of protecting network infrastructure, data in transit, and connected systems from unauthorized access, attacks, and failures

Covers confidentiality, integrity, and availability across:

- Physical networks (LAN, WAN, WLAN)
- Virtual networks (VPNs, SDN, overlays)
- Cloud and containerized environments
- Application delivery layers

Core objectives:

- Prevent unauthorized access
- Detect and respond to threats in real time
- Ensure business continuity and compliance





Why Network Security Matters

- **60% of breaches involve network-layer attacks** (Verizon DBIR 2023)
- **Average cost of a data breach: \$4.45M** (IBM Security Report 2023)
- **Ransomware attacks increased 105% YoY** (Cybersecurity Ventures)

Real impact:

- SolarWinds (2020): Network infiltration via compromised update → 18,000+ organizations affected
- Colonial Pipeline (2021): Lateral movement through VPN → \$4.4M ransom, fuel shortages



"The network is the attack surface. If you don't secure it, everything else is exposed."



LAN Security

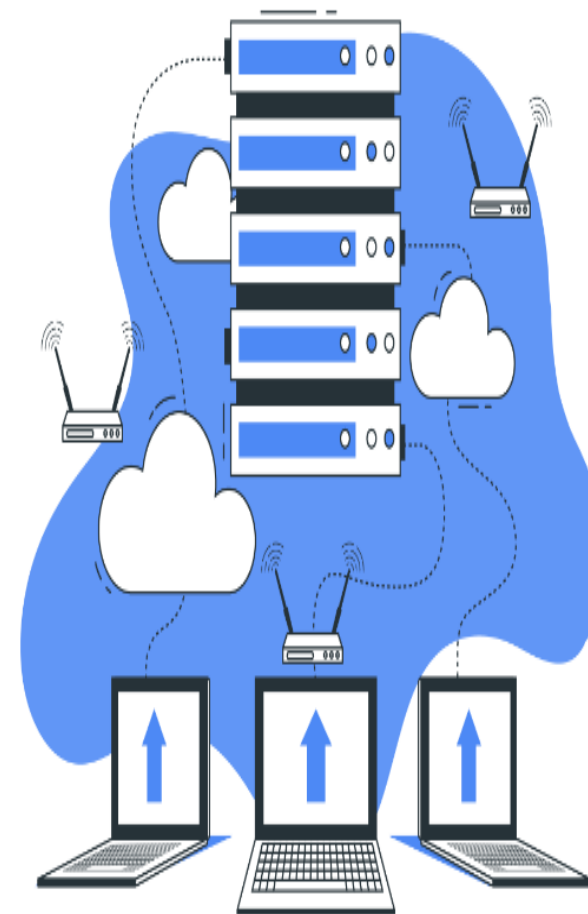
Local Area Network — confined to single physical location (office, campus, datacenter)

Key threats:

- ARP spoofing / poisoning
- MAC flooding and CAM table overflow
- VLAN hopping
- Rogue DHCP servers
- Insider threats via physical access

Mitigation techniques:

- **Port security:** Limit MAC addresses per switch port
- **DHCP snooping:** Prevent rogue DHCP; build IP-MAC binding table
- **Dynamic ARP Inspection (DAI):** Validate ARP packets against DHCP snooping database
- **802.1X (NAC):** Authenticate devices before network access
- **VLAN segmentation:** Isolate traffic by department, function, or trust level





WAN Security

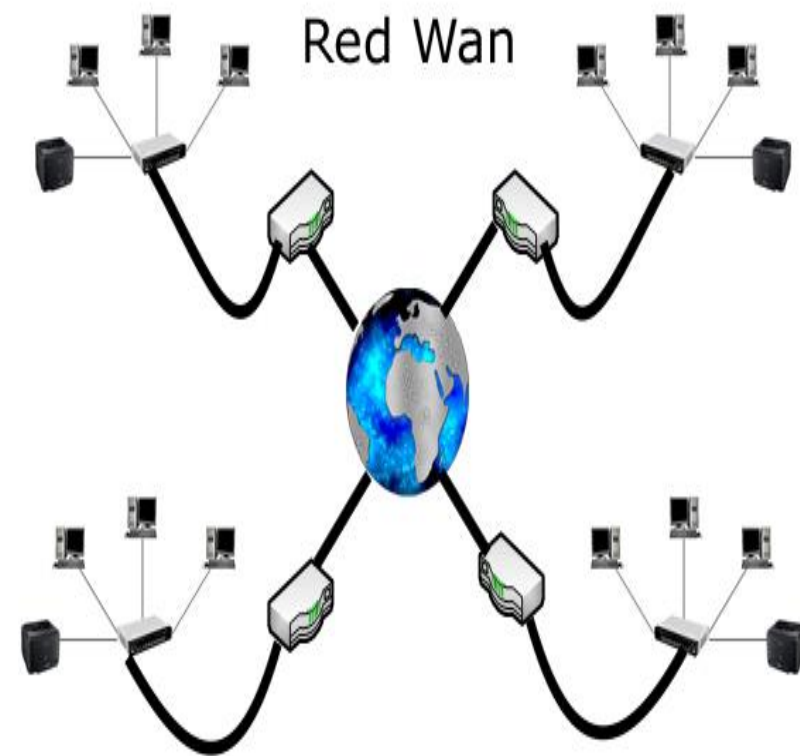
Wide Area Network — connects geographically distributed sites (offices, datacenters, cloud)

Key threats:

- Man-in-the-Middle (MitM) on unencrypted links
- BGP hijacking and route manipulation
- DDoS at WAN edge
- Data exfiltration over long-haul connections

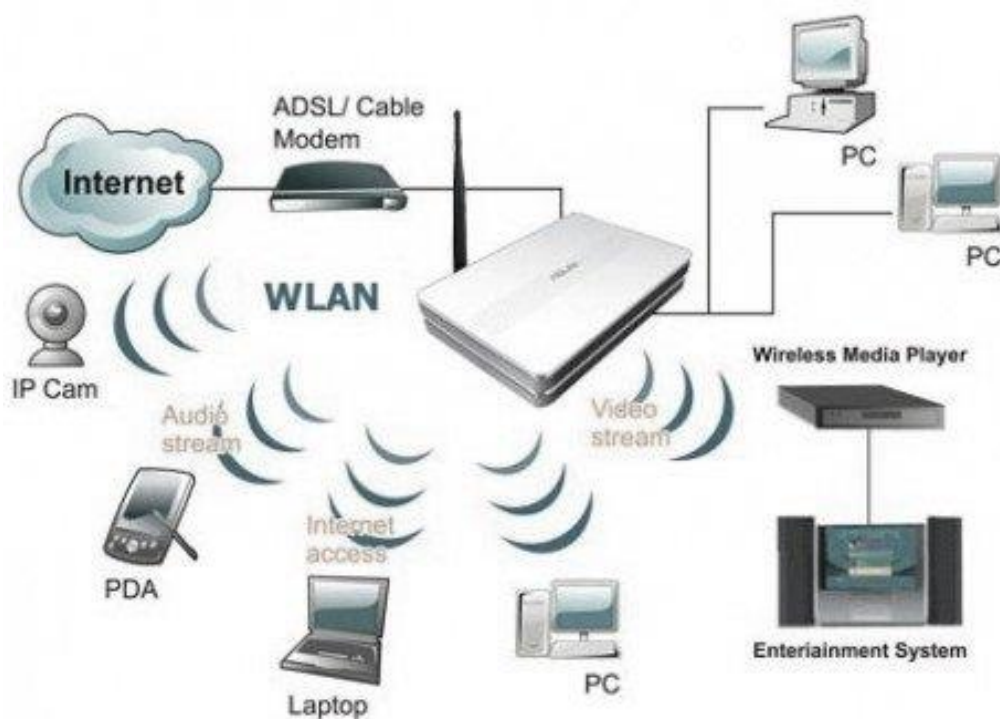
Mitigation techniques:

- **IPsec tunnels:** Encrypt WAN traffic end-to-end
- **MPLS L3VPN:** Traffic isolation via label switching (not encryption alone)
- **SD-WAN with encryption:** Application-aware routing + automated VPN mesh
- **Route filtering (BGP prefix lists, AS-path filters):** Prevent route hijacking
- **DDoS mitigation at ISP/CDN edge:** Scrubbing centers, rate limiting





WLAN Security



Wireless LAN — radio-frequency networks (Wi-Fi), inherently more exposed than wired

Key threats:

- Eavesdropping (passive sniffing of unencrypted traffic)
- Rogue access points / Evil Twin attacks
- Deauthentication attacks (802.11 management frame abuse)
- WEP/WPA cracking
- Client-side attacks via captive portals

Mitigation techniques:

- **WPA3-Enterprise with 802.1X (EAP-TLS):** Certificate-based auth, per-user encryption keys
- **Disable WPS and legacy protocols (WEP, WPA1)**
- **Wireless IDS/IPS (WIDS/WIPS):** Detect rogue APs, deauth floods
- **Client isolation:** Prevent peer-to-peer communication on guest networks
- **Network Access Control (NAC):** Posture assessment before VLAN assignment



Firewalls

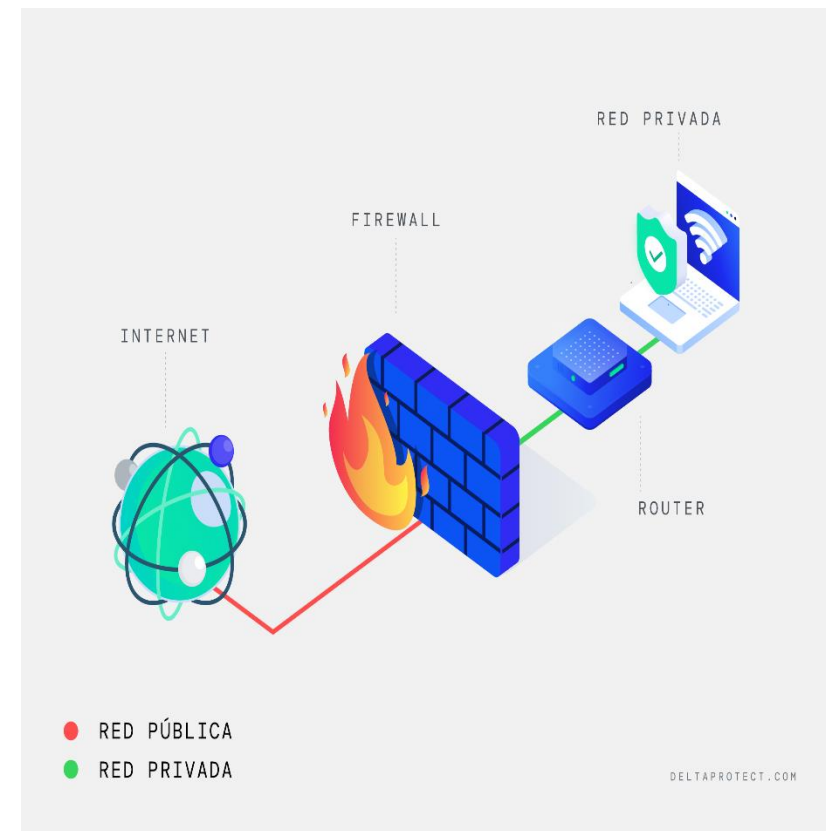
Network device that filters traffic based on policies (allow/deny rules)

Types:

- **Packet-filtering (stateless):** Inspects IP/port headers only (Layer 3–4)
- **Stateful inspection:** Tracks connection state (TCP handshake, session tables)
- **Next-Generation Firewall (NGFW):** Deep packet inspection (DPI), application awareness, integrated IPS, SSL/TLS decryption

Deployment patterns:

- **Perimeter firewall:** Internet edge (north-south traffic)
- **Internal segmentation firewall:** Between VLANs/zones (east-west traffic)
- **DMZ firewall:** Isolates public-facing servers





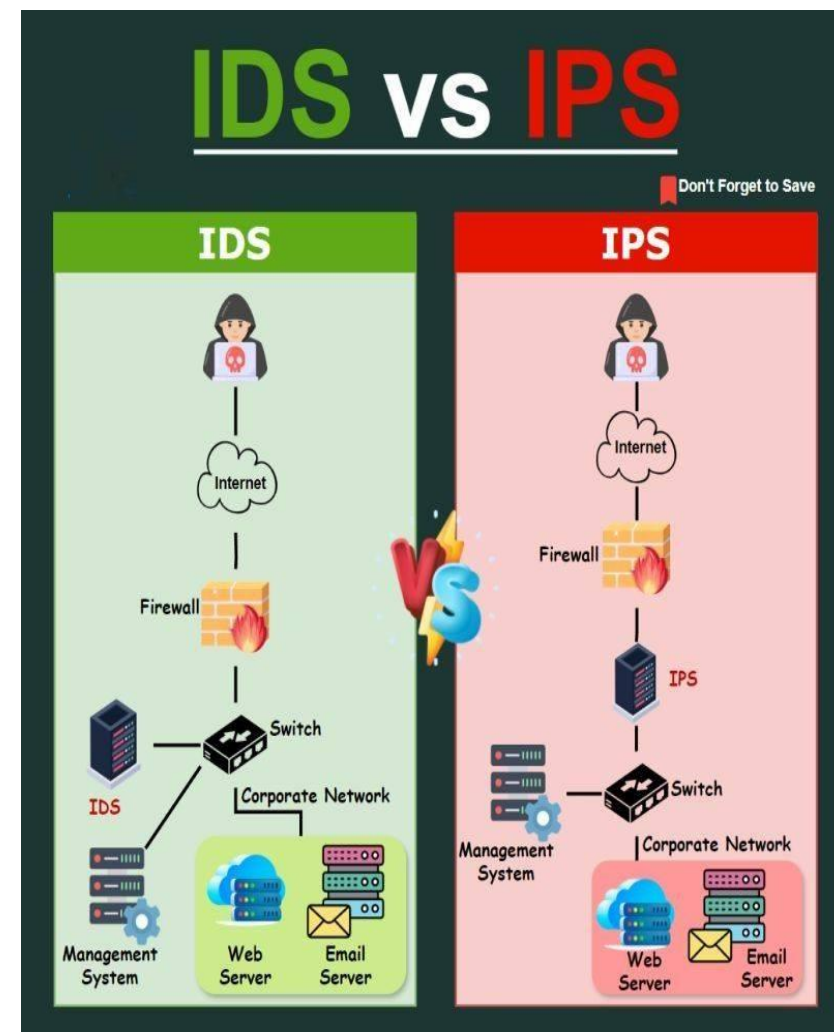
IDS vs. IPS

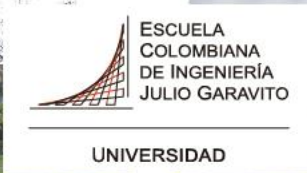
Intrusion Detection System (IDS):

- **Passive monitoring** — analyzes copies of traffic (SPAN port, TAP)
- Generates alerts on suspicious patterns (signatures, anomalies)
- Does NOT block — relies on human/SOAR response
- **Example:** Snort, Suricata, Zeek (Bro)

Intrusion Prevention System (IPS):

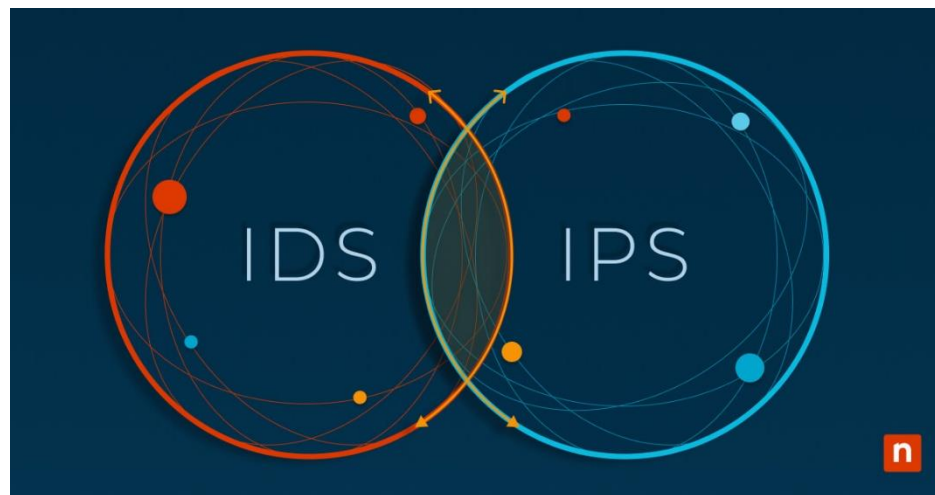
- **Inline deployment** — traffic flows THROUGH the device
- Can drop/block malicious packets in real time
- Higher risk: false positives may break legitimate traffic
- **Example:** Suricata (inline mode), Cisco Firepower, Tipping Point





Detection methods:

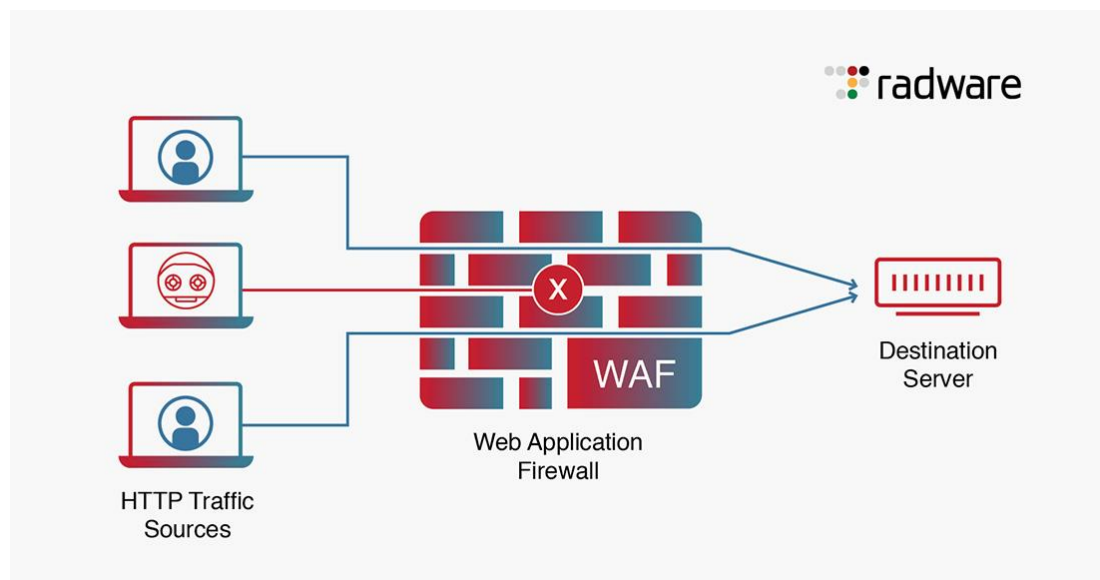
- **Signature-based:** Match known attack patterns (CVEs, malware hashes)
- **Anomaly-based:** Baseline normal behavior, flag deviations (ML models)
- **Protocol analysis:** Detect violations of RFC specs (malformed HTTP, SMB)



Best practice: IDS for visibility + forensics; IPS for automated blocking of high-confidence threats



WAF (Web Application Firewall)



Protects web apps (HTTP/HTTPS) from Layer 7 attacks

Positioned between clients and web servers (reverse proxy mode)

What it blocks:

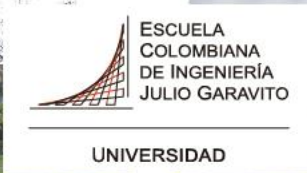
- **OWASP Top 10 attacks:** SQLi, XSS, CSRF, RCE
- **Bot traffic:** Credential stuffing, scraping, DDoS
- **API abuse:** Rate limiting, schema validation
- **Zero-day exploits:** Virtual patching before app code is fixed

Modes:

- **Negative security model (blocklist):** Block known bad patterns
- **Positive security model (allowlist):** Allow only validated requests
- **Hybrid:** Combine both

Example vendors:

- **Cloud WAF:** Cloudflare, AWS WAF, Azure WAF, Akamai
- **On-prem:** ModSecurity (open-source), F5 Advanced WAF, Imperva



VPN (Virtual Private Network)

Creates encrypted tunnel over untrusted networks (Internet) to connect remote users or sites

Types:

1. Remote Access VPN:

- User → Corporate network
- Protocols: SSL/TLS (clientless, browser-based), IPsec (client app)
- **Example:** Cisco AnyConnect, OpenVPN, WireGuard

2. Site-to-Site VPN:

- Office ↔ Datacenter or Cloud
- Protocols: IPsec, GRE over IPsec
- **Example:** AWS VPN, Meraki Auto VPN

Security considerations:

- **Split tunneling:** Only corporate traffic via VPN (reduces bandwidth) vs. full tunnel (all traffic)
- **MFA enforcement:** Required for remote access
- **Certificate-based auth (IKEv2):** Stronger than PSK
- **Kill switch:** Block Internet if VPN drops



Modern alternative: ZTNA (Zero Trust Network Access) — no VPN, per-app access via identity proxy



Cloud Security Fundamentals

Shared Responsibility Model:

- **Cloud Provider secures:** Physical infra, hypervisor, network backbone
- **Customer secures:** OS, apps, data, IAM, network configs

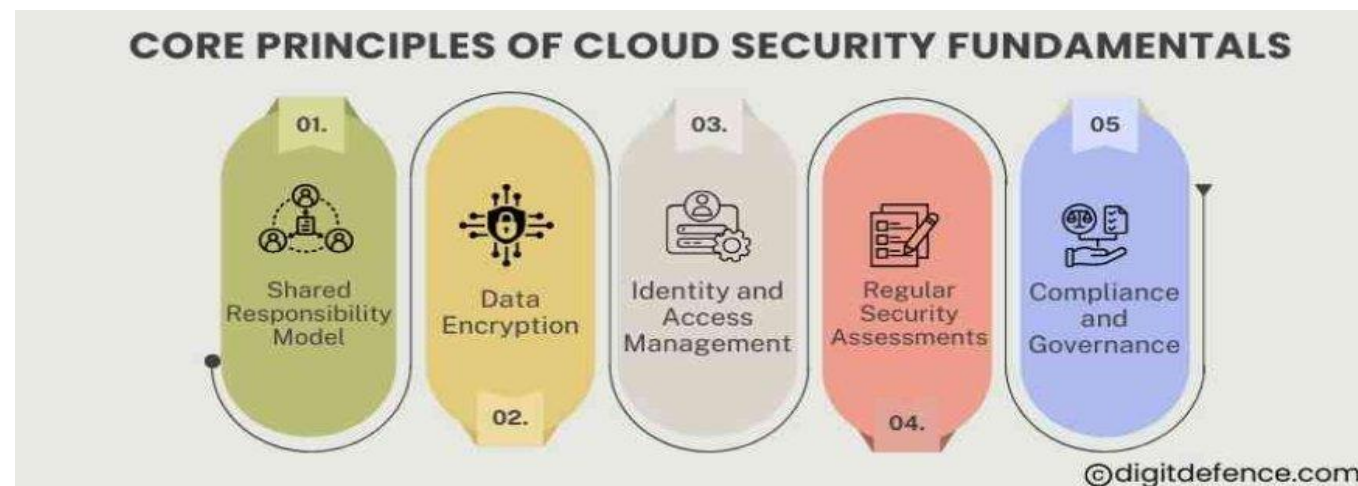
Key pillars:

1. Identity & Access Management (IAM):

- Least privilege, role-based access (RBAC)
- Service accounts with short-lived tokens
- **Example:** AWS IAM policies, Azure RBAC, GCP IAM

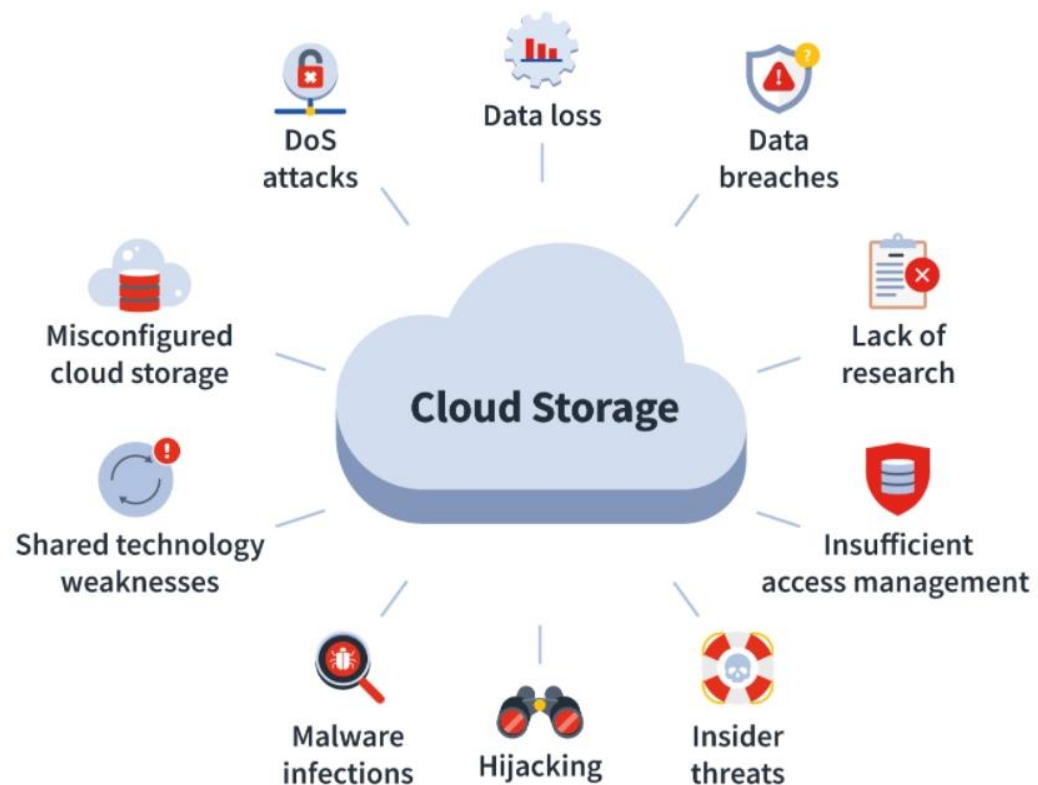
2. Network segmentation:

- VPC (Virtual Private Cloud), subnets, security groups
- **Egress control:** Block outbound to unknown IPs (data exfiltration)





Cloud Security Risks You Need To Know



3.

Encryption:

- **At rest:** S3 SSE, Azure Storage Service Encryption, GCP CMEK
- **In transit:** TLS 1.2+, VPN to on-prem

4.

Logging & monitoring:

- CloudTrail (AWS), Azure Monitor, GCP Cloud Logging
- SIEM integration (Splunk, Sentinel, Chronicle)

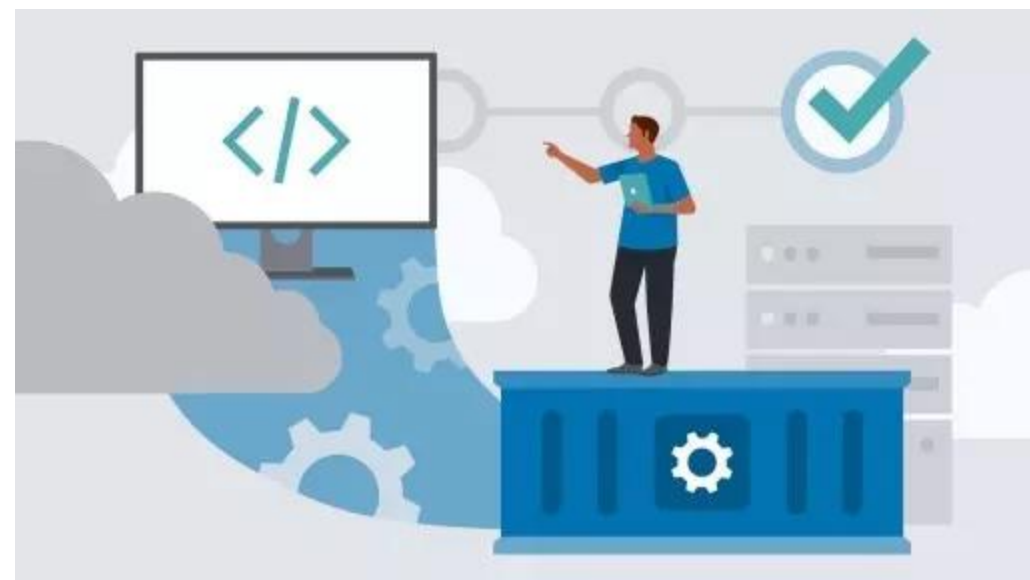


Container Security

Containers (Docker, Podman) share host OS kernel → unique attack surface

Threat model:

- **Container escape:** Break out to host OS via kernel exploit
- **Image vulnerabilities:** Outdated base images, embedded secrets
- **Privileged containers:** Root access to host resources
- **Supply chain attacks:** Malicious images from public registries





Security best practices:

1. Image scanning:

- Scan for CVEs before deployment (Trivy, Clair, Snyk)
- **Example:** `trivy image nginx:latest`

2. Minimal base images:

- Use distroless, alpine, or scratch — reduce attack surface
- **Bad:** `FROM ubuntu` (300MB, full shell)
- **Good:** `FROM gcr.io/distroless/python3` (50MB, no shell)

3. Runtime security:

- Drop unnecessary capabilities (`--cap-drop ALL`)
- Read-only root filesystem (`--read-only`)
- Non-root user inside container

4. Secrets management:

- NEVER bake secrets into images
- Use: Docker secrets, Kubernetes Secrets, HashiCorp Vault





Kubernetes Security

K8s orchestrates containers at scale → complex, multi-layered attack surface

4C's of Kubernetes Security:

1. **Code:** Secure app code (SAST, DAST, SCA)
2. **Container:** Scan images, drop privileges, read-only FS
3. **Cluster:** RBAC, network policies, admission control
4. **Cloud:** Secure K8s control plane, node IAM, encryption

Key attack vectors:

- **Exposed API server:** Unauthenticated kubectl access
- **Overly permissive RBAC:** Pods with cluster-admin
- **No network policies:** Lateral movement between namespaces
- **Privileged pods:** HostPath mounts, hostNetwork=true



kubernetes



Kubernetes Security — Controls



1. RBAC (Role-Based Access Control)
2. Network Policies
3. Pod Security Standards (PSS):
 - Restricted: No privileged, no hostPath, drops all capabilities
 - Baseline: Minimal restrictions
 - Privileged: Unrestricted (never use in prod)
4. Admission Controllers:
 - OPA Gatekeeper: Policy-as-code (deny non-HTTPS ingress)
 - Kyverno: Mutate/validate resources (auto-inject sidecar, enforce labels)



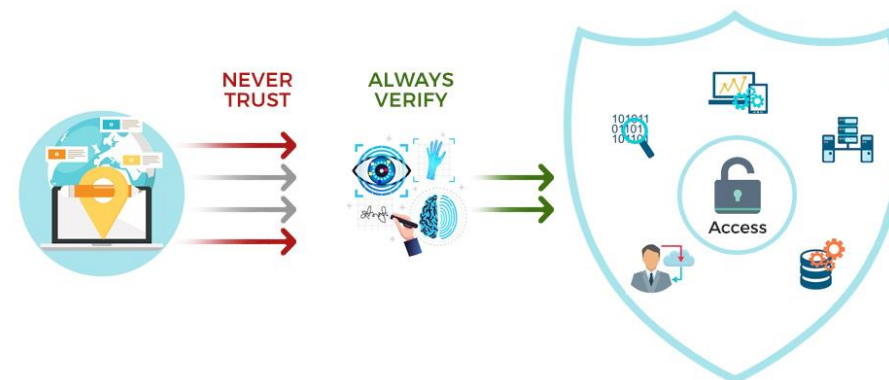
Zero Trust Architecture (ZTA)

"Never trust, always verify" — assume breach, verify every request

Core principles (NIST SP 800-207):

- **Verify explicitly:** Authenticate & authorize based on all available data points (identity, device, location, behavior)
- **Least privilege access:** Grant minimum necessary permissions, just-in-time (JIT)
- **Assume breach:** Segment network, encrypt E-W traffic, monitor continuously
- **Traditional perimeter model:**
 - Trust everything inside the network
 - VPN grants broad access
 - **Problem:** Lateral movement after breach (SolarWinds, Colonial Pipeline)
- **Zero Trust model:**
 - No implicit trust based on network location
 - Micro-segmentation: policy per workload/app
 - Identity is the new perimeter

ZERO TRUST SECURITY





Zero Trust — Implementation Pillars

1. Identity:

- SSO with MFA (Okta, Azure AD, Google Workspace)
- Conditional access: block risky sign-ins (impossible travel, brute force)
- Device compliance checks (managed, patched, encrypted)

2. Devices:

- Endpoint Detection & Response (EDR): CrowdStrike, SentinelOne
- Mobile Device Management (MDM): Enforce encryption, remote wipe

3. Network:

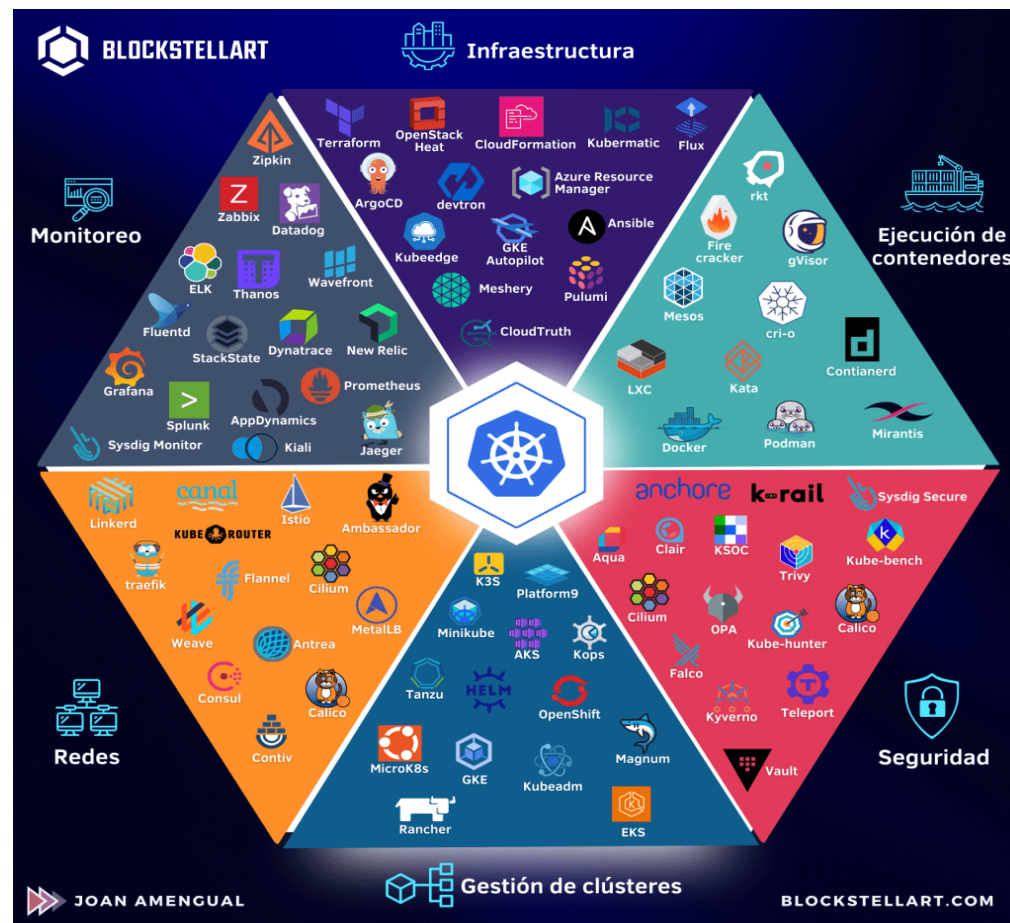
- **Software-Defined Perimeter (SDP):** Hide infra by default, grant access post-auth
- **ZTNA (Zero Trust Network Access):** Replace VPN (Zscaler, Cloudflare Access, Palo Alto Prisma)

4. Applications:

- Per-app access via identity proxy
- Reverse proxy with continuous auth checks

5. Data:

- Data Loss Prevention (DLP): Monitor/block sensitive data exfiltration
- Encryption: E2E encryption for sensitive assets



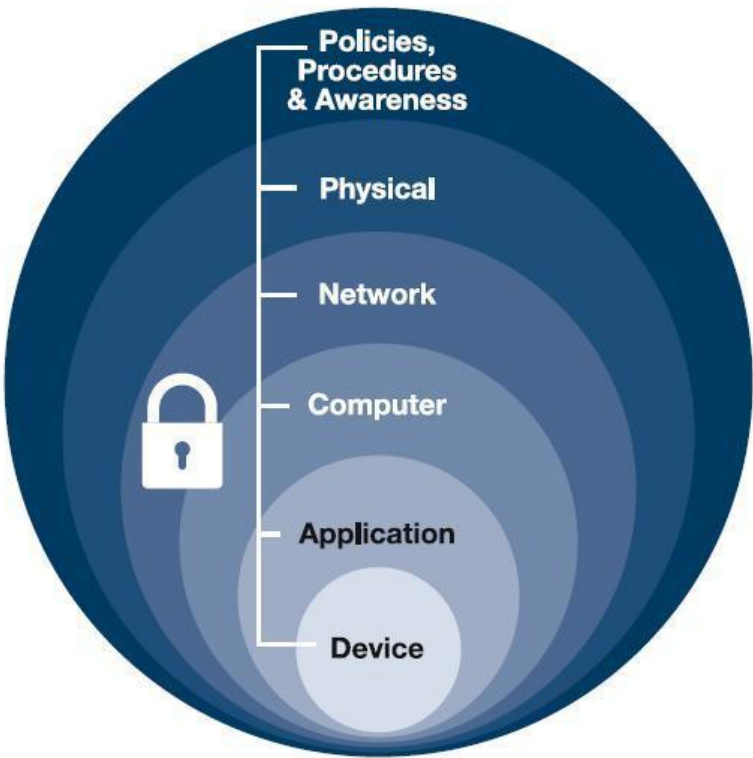


Defense in Depth

Layered security controls — no single point of failure

Example stack (datacenter):

Layer	Control
Physical	Badge access, cameras, biometrics
Perimeter	NGFW, DDoS mitigation
Network	VLAN segmentation, IPS, NAC
Host	EDR, patch management, disk encryption
Application	WAF, secure coding, input validation
Data	Encryption, DLP, tokenization
Identity	MFA, RBAC, least privilege



Principle: Attacker must breach multiple layers — each layer slows and exposes them



Security Monitoring & Incident Response

SIEM (Security Information & Event Management):

- Aggregate logs from firewalls, IDS, endpoints, cloud
- Correlate events to detect attacks (e.g., failed login → privilege escalation → data exfil)
- **Examples:** Splunk, Elastic Security, Microsoft Sentinel, Chronicle

Key log sources:

- Firewall: blocked connections, port scans
- IDS/IPS: exploit attempts, C2 communication
- VPN: auth failures, anomalous locations
- Cloud: IAM changes, S3 bucket access, EC2 egress spikes

Incident Response phases (NIST):

1. **Preparation:** Runbooks, tools, training
2. **Detection & Analysis:** SIEM alerts, forensics
3. **Containment:** Isolate compromised systems
4. **Eradication:** Remove malware, close backdoors
5. **Recovery:** Restore from backups, patch
6. **Lessons Learned:** Post-mortem, update defenses





References

- **NIST SP 800-207:** Zero Trust Architecture
<https://csrc.nist.gov/publications/detail/sp/800-207/final>
- **OWASP Kubernetes Top 10:**
<https://owasp.org/www-project-kubernetes-top-ten/>
- **CIS Benchmarks:** Hardening guides (Docker, K8s, AWS, Azure)
<https://www.cisecurity.org/cis-benchmarks>
- **Verizon DBIR 2023:** Data Breach Investigations Report
<https://www.verizon.com/business/resources/reports/dbir/>
- **MITRE ATT&CK:** Adversary tactics & techniques
<https://attack.mitre.org/>

Gracias